République du Cameroun
Paix-Travail-Patrie
****
Ministère de l'Enseignement Supérieur
****
Université de Garoua
****
Faculté des Sciences
****
Division des Affaires Académiques, de la Scolarité et de la Recherche

Republic of Cameroon
Peace-Work-Fatherland
****
Ministry of Higher Education
****
Université of Garoua
****
Faculté of Science
****
Division of Academic Affairs, Student's Admission and Research

UE : Supervision, Analyse Forensique et Gestion des incidents

N°	Noms et prénoms	Matricule	NIVEAU
1	PEDENE OUMAROU JEAN PAUL	CM-UGa-24FS0782	MASTER II

Année Académique : 2025-2026

TRAVAIL PRATIQUE DU CHAPITRE I

Ex. 1.1 — Diagnostic de maturité. Appliquez la grille (tab. 1.3) à LiZbiZ-SIS.

Niveau 1

Justification :Le SOC n'a aucune visibilité structurée. Sans SIEM ni collecte centralisée des logs, la détection dépend entièrement des signalements utilisateurs. Le MTTD > 7 jours signifie qu'une attaque peut persister plus d'une semaine sans être détectée, exposant l'organisation à des dommages critiques (exfiltration, ransomware, pivoting).

correctives prioritaires :

- Déployer un SIEM de base (ex. Elastic SIEM, Microsoft Sentinel) avec collecte des logs AD, firewall et endpoints
- Définir un processus minimal de gestion des incidents avec des niveaux de sévérité et une astreinte d'escalade

Niveau 2

Justification : Le SIEM est en place mais les règles par défaut génèrent un volume d'alertes non triées, provoquant de la fatigue d'alerte. Les analystes passent leur temps à trier manuellement, ce qui maintient le MTTD entre 2 et 7 jours et masque les incidents réels dans le bruit.

correctives prioritaires :

- Implémenter un système de ticketing et de triage (ex. TheHive) avec priorisation automatique par criticité actif/vulnérabilité
- Affiner et contextualiser les règles de détection en désactivant les règles à fort taux de faux positifs et en les adaptant au contexte métier

Niveau 3

Justification : Les règles sont personnalisées et le triage est opérationnel (FPR < 50 %), mais la détection reste réactive. Le SOC répond aux alertes sans anticiper les menaces. Le MTTD < 24 h est acceptable mais insuffisant face aux attaques modernes dont le temps de déplacement latéral peut être inférieur à quelques heures.

correctives prioritaires :

- Intégrer une source de Cyber Threat Intelligence (CTI) pour enrichir les alertes avec des IOCs et TTPs connus (MITRE ATT&CK)
- Mettre en place des métriques SOC formelles (MTTD, MTTR, taux de faux positifs) pour piloter l'amélioration continue

Niveau 4

Justification : Le threat hunting proactif et la CTI intégrée permettent d'atteindre un FPR < 30 % et un MTTD < 4 h. Cependant, les processus de réponse restent majoritairement manuels, ce qui crée un goulot d'étranglement humain à grande échelle et limite la capacité à traiter des volumes d'incidents élevés.

correctives prioritaires :

- Déployer une plateforme SOAR (ex. Splunk SOAR, Palo Alto XSOAR) pour automatiser les playbooks de réponse sur les incidents récurrents
- Structurer un programme de threat hunting récurrent avec des hypothèses documentées basées sur les campagnes actives (OSINT, ISACs sectoriels)

Niveau 5

Justification : C'est le niveau d'excellence opérationnelle. Le SOAR, le ML et l'automatisation permettent une détection prédictive avec un MTTD < 1 h. Le risque à ce stade est la dépendance technologique et la dérive des modèles ML sur de nouvelles menaces, ainsi que la difficulté à maintenir les compétences humaines face à l'automatisation croissante.

Actions correctives prioritaires :

- Mettre en place un programme de red team/purple team continu pour valider en permanence l'efficacité des détections et éviter l'effet « fausse sécurité »
- Gouverner et auditer les modèles ML (drift detection, biais, réentraînement régulier) pour garantir leur pertinence face à l'évolution des TTPs adversaires

Ex. 1.2 — Sélection de sources.

1. **Serveur Windows AD**

Justification : L'AD est le cœur de l'authentification et de la gestion des droits. Sa compromission implique la compromission totale du SI. C'est la cible privilégiée des attaquants en phase de post-exploitation.

2. **Firewall pfSense**

Justification : Le firewall est l'unique point d'entrée/sortie du réseau. Il offre une visibilité totale sur le trafic périmétrique et permet de détecter aussi bien les attaques entrantes que les exfiltrations sortantes.

3. **Proxy Squid**

Justification : Tout le trafic web des utilisateurs transite par le proxy Squid. Il constitue un point de détection clé des infections par malware via le web (phishing, drive-by download) et des communications C2 en HTTP/HTTPS.

4. **Serveur Linux Apache**

Justification : Le serveur Apache est potentiellement exposé sur Internet, constituant une surface d'attaque externe directe. Les logs applicatifs permettent de détecter des attaques web avant toute compromission interne.

5. **Serveur Windows ERP**

Justification : L'ERP héberge les données métier les plus sensibles (financier, RH, clients). Un accès non autorisé ou une exfiltration depuis ce serveur aurait un impact critique pour l'entreprise.

Tableau indiquant les menace

Priorité	Source	Menace principale couverte
1	**Active Directory (Windows)**	Compromission d'identité, escalade de privilèges
2	**Firewall pfSense**	Intrusion périmétrique, exfiltration réseau
3	**Proxy Squid**	Malware, C2, phishing web
4	**Serveur Linux Apache**	Attaque web, web shell, exploitation CVE
5	**Serveur Windows ERP**	Vol de données métier, mouvement latéral

Ex. 1.3 — Règle de corrélation

```
<!-- Règle de base : connexion SMB réussie (Event 4624 LogonType 3) -->
<rule id="100200" level="5">
  <if_sid>60103</if_sid>  <!-- Windows logon success -->
  <field name="win.eventdata.logonType">3</field>
  <description>SMB Network Logon réussi depuis un poste</description>
</rule>
```

TRAVAIL PRATIQUE DU CHAPITRE II

Ex. 2.2 — Configuration Rsyslog

```
action(
  name    = "siem_tls_forward"
  type    = "omfwd"
  target          = "10.0.0.5"
  port            = "6514"
  protocol        = "tcp"
# — TLS ————————————————————————————————————————————————
  StreamDriver        = "gtls"
  StreamDriverMode    = "1"          # 1 = TLS obligatoire (pas de fallback clair)
  StreamDriverAuthMode  = "x509/name"    # authentification par certificat CN

  # — Format ————————————————————————————————————————————
  template        = "RFC5424fmt"

  # — File d'attente persistante
  # Les fichiers de queue seront créés dans /var/lib/rsyslog/
  queue.type          = "linkedList"    # type de file en mémoire
  queue.filename      = "siem_fwd_queue"  # nom de base des fichiers sur disque
  queue.maxdiskspace  = "200m"          # espace disque maximum pour la queue
  queue.size          = "10000"         # nombre max de messages en mémoire
  queue.highwatermark = "9000"          # début du déversement sur disque
```

```
    queue.lowwatermark      = "1000"          # retour en mode mémoire
    queue.saveonshutdown    = "on"            # sauvegarde de la queue à l'arrêt
    queue.dequeuebatchsize  = "100"           # messages traités par lot

    # — Reconnexion automatique si le SIEM est indisponible ——————————
    action.resumeRetryCount = "-1"            # -1 = réessayer indéfiniment
    action.resumeInterval   = "30"            # intervalle de 30 s entre tentatives
)
```

Ex. 2.3 — Analyse de la timeline.

(a) Durée entre le premier scan et la première connexion réussie

Événement	Timestamp UTC
Scan SYN port 22 (pfSense)	2026-04-12 02:47:11
Authentification SSH réussie (user: backup)	2026-04-12 03:14:51

Durée totale : 27 minutes et 40 secondes

(b) EID confirmant l'effacement des journaux

EID 1102 (Security) — srv-erp-01 — 2026-04-12 à 03:48:00

(c) Technique MITRE du mouvement latéral

T1021.002 — Remote Services: SMB/Windows Admin Shares

(d) Deux mesures qui auraient interrompu la chaîne dès l'étape 3

Mesure	Explication
MFA sur SSH	Même avec le bon mot de passe, une 2e preuve (TOTP, clé physique) aurait bloqué la connexion depuis l'IP externe.
Fail2Ban / blocage IP automatique	Après 7 échecs SSH en 45 secondes, l'IP 203.0.113.42 aurait dû être automatiquement bannie avant la connexion réussie.